UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

UNIVERSIDAD POLITÉCNICA DE

SAN LUIS POTOSÍ

CARRERA: Ingeniería en Tecnologías de la Información

MATERIA: CNO IV Seguridad Informática

TRABAJO: Plan de Respuesta Ante Incidentes

Ojeda Camacho José Carlos / 181629

PROFESOR: Mtro. Servando López Contreras

Contenido

1. Propósito, Alcance y Clasificación 4
   Propósito 4
   Alcance 4
   Concepto de Incidente de Ciberseguridad 4
   Criterios de Severidad y Prioridades 4
   Condiciones de Activación 4
2. Roles y Responsabilidades 5
3. Preparación, Detección y Reporte 6
   3.1 Mecanismos Previos de Preparación 6
   3.2 Fuentes de Detección y Recepción de Alertas 6
   3.3 Registro y Canales para Reportar Incidentes 7
4. Análisis y Priorización 7
   4.1 Procedimiento de Triage y Validación 7
   4.2 Determinación de Alcance y Clasificación 8
   4.3 Preservación de Evidencia (Cadena de Custodia) 8
   4.4 Criterios de Escalamiento 8
5. Contención 9
   5.1 Estrategias de Contención Inmediata 9
   5.2 Estrategias de Contención Prolongada 9
   5.3 Continuidad Operativa y Gestión del Riesgo 10
   5.4 Preservación de Evidencia 10
6. Erradicación y Remediación (PR02-36) 10
   6.1 Eliminación de Causas y Corrección de Vulnerabilidades 10
   6.2 Eliminación de Persistencia 11
   6.3 Validación de Controles antes de Recuperar 11
7. Recuperación 12
   7.1 Procedimientos de Restauración Segura 12
   7.2 Pruebas y Validación Funcional 12
   7.3 Monitoreo Reforzado (Hypercare) 13
   7.4 Criterios para Volver a Operación (Go-Live) 13
   7.5 Mecanismos de Rollback (Marcha Atrás) 13
8. Coordinación y Comunicación (PR02-38) 13

9. Playbooks Operativos (PR02-39) 14
Playbook 1: Inyección SQL en Plataforma de Atención Ciudadana 14
Playbook 2: Explotación de IDOR (Acceso No Autorizado a Expedientes) 15
Playbook 3: Manipulación Remota de Nodos SCADA (V-SL-201)..... 15
Playbook 4: Intrusión Perimetral por IP Spoofing 16
Playbook 5: Compromiso de Credenciales de la Mesa de Soporte (MFA Bypass)..... 16
10. Post-Incidente y Mejora 17
10.1 Declaratoria y Cierre Formal del Incidente 17
10.2 Elaboración del Informe Final 18
10.3 Plan de Acción Correctiva y Preventiva (CAPA) y Lecciones Aprendidas..... 18
10.4 Métricas de Evaluación de Desempeño (KPIs de Respuesta) 19
10.5 Gobernanza, Responsables y Seguimiento hasta la Resolución..... 19
Conclusion..... 20

1. Propósito, Alcance y Clasificación

Propósito

Establecer una metodología estructurada, repetible y auditable para preparar, detectar, analizar, contener, erradicar y recuperar los sistemas de información y la infraestructura crítica de INTERAFAS ante eventos adversos de ciberseguridad, garantizando la continuidad del suministro hídrico metropolitano y la protección de los datos ciudadanos.

Alcance

Este plan es de observancia obligatoria para todo el personal operativo, administrativo y directivo, y cubre toda la infraestructura tecnológica de la institución, abarcando:

- **Entorno IT:** Plataforma de Atención Ciudadana Digital, pasarelas de pago, bases de datos ciudadanas y red corporativa.
- **Entorno OT:** Red de control industrial, nodos SCADA, unidades terminales remotas (RTU) y la estación principal de distribución (V-SL-201).

Concepto de Incidente de Ciberseguridad

Cualquier evento o serie de eventos anómalos que comprometan la Confidencialidad, Integridad o Disponibilidad (CIA) de los activos de información o los procesos automatizados de INTERAFAS, o que violen las políticas funcionales del SGSI.

Criterios de Severidad y Prioridades

Los incidentes se clasifican para asignar recursos y tiempos de respuesta (SLA):

1. **Prioridad 1 - Nivel Crítico (Severo):** Afectación directa a la red OT (pérdida de control de válvulas), exfiltración masiva de expedientes ciudadanos o indisponibilidad total de la red IT/OT que impida el suministro de agua. *Respuesta Inmediata (24/7)*.
2. **Prioridad 2 - Nivel Alto:** Compromiso de servidores IT críticos (ej. ataques de Inyección SQL detectados en curso) o indisponibilidad de la pasarela de pagos, sin afectación a la red industrial. *Respuesta en < 1 hora*.
3. **Prioridad 3 - Nivel Medio:** Infección de *malware* aislada en estaciones de trabajo administrativas o intentos de acceso no autorizado (fuerza bruta) fallidos pero recurrentes. *Respuesta en < 4 horas*.
4. **Prioridad 4 - Nivel Bajo:** Anomalías de red rutinarias, correos de *phishing* bloqueados por el filtro perimetral. *Revisión en horario hábil*.

Condiciones de Activación

El plan se detona oficialmente cuando el Centro de Operaciones de Seguridad (SOC) o la Mesa de Ayuda validan un reporte de actividad sospechosa que supere el Nivel Bajo,

mediante alertas del SIEM, reportes de usuarios internos o notificaciones de proveedores externos.

2. Roles y Responsabilidades

Para garantizar una respuesta coordinada, se constituye el Equipo de Respuesta a Incidentes de Ciberseguridad (CSIRT-INTERAFAS), operando bajo las siguientes funciones claramente asignadas:

- **Líder del Equipo (Dirección Ejecutiva):** *Mtra. Valeria Serrano Cruz (Dirección General).*
    - Autoriza el escalamiento de recursos financieros, declara el estado de contingencia y aprueba la interrupción total de servicios críticos (como el apagado de la planta).
- **Responsable Técnico de Respuesta IT:** *Ing. Bruno Ferrer Lozano (Tecnologías e Innovación).*
    - Dirige las acciones de triaje, contención lógica y aislamiento de redes corporativas. Coordina el análisis forense de la base de datos y plataformas web (IDOR, SQLi).
- **Responsable Técnico de Respuesta OT:** *Ing. Tomás Rivas Calderón (Operación Hidráulica).*
    - Gestiona la transición segura del control SCADA automatizado a la operación manual en campo. Verifica la integridad de los controladores mecánicos.
- **Responsable Jurídico y de Cumplimiento:** *Lic. Camila Ortega Neri (Dirección Jurídica).*
    - Asegura la preservación de la cadena de custodia de la evidencia digital para acciones legales. Coordina notificaciones obligatorias ante el INAI por vulneración de datos.
- **Responsable de Comunicación:** *Mtra. Natalia Correa Vidal (Atención Ciudadana).*
    - Ejecuta el Plan de Comunicación de Crisis, actuando como enlace con la ciudadanía y medios locales.
- **Terceros y Proveedores Externos:**
    - *Proveedor de Hosting / Nube:* Notificación de anomalías perimetrales y provisión de bitácoras (*logs*) de pasarelas de pago.
    - *Auditores Forenses Externos:* Intervención en incidentes Prioridad 1 para realizar ingeniería inversa de *malware* o análisis de brechas complejas.

3. Preparación, Detección y Reporte

Para anticipar y mitigar el impacto de posibles amenazas sobre la infraestructura hídrica y de datos de INTERAFAS, se establecen los siguientes mecanismos previos de preparación, fuentes de detección y canales formales para el reporte de incidentes.

3.1 Mecanismos Previos de Preparación

La fase de preparación es el pilar proactivo del equipo CSIRT-INTERAFAS e incluye las siguientes medidas:

- **Hardening de Infraestructura:** Implementación estricta de la segmentación entre las redes IT (corporativa) y OT (industrial), uso de tokens físicos (FIDO2) para el acceso a paneles SCADA y parcheo continuo de vulnerabilidades web (Inyección SQL, IDOR).
- **Respaldo de Información:** Ejecución automatizada de *backups* bajo la regla 3-2-1 (tres copias, dos medios distintos, uno *off-site* o inmutable), con pruebas de restauración semestrales para asegurar la recuperación de las bases de datos ciudadanas.
- **Capacitación Continua:** Simulacros de *phishing* trimestrales para el personal administrativo y talleres de concientización basados en el material preventivo del SGSI.
- **Kits de Respuesta:** Mantenimiento de repositorios seguros (fuera de la red principal) con diagramas de red actualizados, listas de contactos de emergencia, manuales de equipos SCADA y *software* forense para la recolección de evidencia.

3.2 Fuentes de Detección y Recepción de Alertas

La detección temprana de un compromiso en INTERAFAS provendrá de dos frentes principales:

1. **Detección Automatizada (Tecnológica):**
    - **SIEM (Security Information and Event Management):** Recepción centralizada de bitácoras (*logs*) que correlaciona eventos anómalos, como múltiples inicios de sesión fallidos o picos de tráfico inusuales hacia la base de datos ciudadana.
    - **WAF (Web Application Firewall) e IDS/IPS:** Alertas de intentos de inyección de código en el portal web o escaneos de puertos dirigidos a la pasarela de pagos.
    - **Monitoreo OT:** Sensores de red industrial que detectan comandos no autorizados o lecturas de telemetría alteradas dirigidas a los actuadores y válvulas (ej. V-SL-201).
2. **Detección Manual (Humana):**

- Reportes de operadores del Centro de Operación Hidráulica que identifiquen lentitud en la interfaz HMI o bloqueos de sistema.
- Notificaciones de usuarios externos (ciudadanos) que reporten fallos, alteraciones en sus estados de cuenta o indisponibilidad en la Plataforma Digital.

3.3 Registro y Canales para Reportar Incidentes

Todo evento anómalo, sin importar su aparente severidad inicial, debe ser documentado y canalizado a través de vías oficiales para evitar la pérdida de información vital durante las primeras horas críticas.

- **Mesa de Ayuda Interna (HelpDesk):** Canal primario para el personal de INTERAFAS. Los reportes se pueden realizar vía extensión telefónica de emergencia (Ext. 911-IT) o mediante un formulario de la intranet que genera un *ticket* automático.
- **Buzón de Ciberseguridad:** Correo electrónico dedicado (soc@interafas.gob.mx) para recibir notificaciones de proveedores tecnológicos o alertas automatizadas de los sistemas de monitoreo.
- **Sistema de Registro (Ticketing):** Todo incidente reportado se registrará en la plataforma de gestión de servicios (ITSM), documentando obligatoriamente: fecha y hora de la detección, persona que reporta, descripción de los síntomas, sistemas afectados (IT/OT) y la criticidad preliminar estimada.

4. Análisis y Priorización

Una vez que un incidente o evento anómalo ha sido detectado y reportado a través de los canales oficiales, el equipo CSIRT-INTERAFAS debe ejecutar un proceso de triaje para determinar su veracidad, alcance y urgencia, garantizando que los recursos se enfoquen en proteger los sistemas críticos.

4.1 Procedimiento de Triage y Validación

El proceso de triaje es el primer filtro técnico. Su objetivo es descartar falsos positivos y confirmar si el evento reportado constituye un incidente real de ciberseguridad.

1. **Recepción y Asignación:** La alerta ingresa al sistema de *ticketing*. El Analista SOC en turno (Nivel 1) asume la titularidad del reporte.
2. **Validación Técnica:** El analista correlaciona la alerta con otras fuentes. Por ejemplo, si un operador reporta que la válvula V-SL-201 no responde, el analista verifica si existen registros simultáneos de fallas de red, intentos de acceso remoto anómalos o actualizaciones no programadas en el firewall industrial.
3. **Descarte o Confirmación:** Si el evento es un fallo de hardware aislado (ej. un cable desconectado), se reclasifica como "Falla de Soporte IT/OT". Si existen indicios de

actividad maliciosa (ej. inyección de comandos o tráfico exfiltrado), se declara un "Incidente de Ciberseguridad Confirmado".

4.2 Determinación de Alcance y Clasificación

Una vez confirmado el incidente, el Responsable Técnico (IT u OT) debe dimensionar el daño potencial para clasificarlo correctamente:

- **Alcance Lógico:** ¿Qué sistemas están comprometidos? (ej. Solo el portal web, la base de datos de facturación, o los controladores SCADA).
- **Alcance Físico/Operativo:** ¿El incidente afecta la presión del agua, el suministro de energía de las bombas o expone expedientes ciudadanos?
- **Clasificación de Severidad:** Con base en el alcance, el incidente se clasifica siguiendo los criterios de la Sección 1 (Bajo, Medio, Alto, Crítico/Severo).

4.3 Preservación de Evidencia (Cadena de Custodia)

Antes de apagar servidores o borrar archivos para "limpiar" el sistema, se debe asegurar la evidencia para el análisis forense y el cumplimiento legal (especialmente si hay robo de datos ciudadanos).

1. **Congelamiento del Estado:** En incidentes críticos (Nivel Alto/Severo), no se apaga el equipo afectado de forma abrupta. En su lugar, se aísla de la red (desconexión lógica o física del cable) para mantener la memoria RAM intacta.
2. **Volcado de Memoria y Discos:** Se ejecutan herramientas forenses (ej. *FTK Imager* o *dd*) para crear imágenes exactas (bit a bit) de la memoria y los discos duros comprometidos.
3. **Aseguramiento de Bitácoras (*Logs*):** Se extraen de forma segura los registros del firewall, SIEM, servidores web y controladores de dominio de las últimas 72 horas, calculando sus firmas criptográficas (hashes SHA-256) para garantizar que no sean alterados posteriormente.

4.4 Criterios de Escalamiento

Si durante el triaje y análisis preliminar se descubre que la magnitud del incidente supera la capacidad operativa del nivel actual, se debe escalar inmediatamente:

- **Escalamiento Técnico:** Si el Analista SOC (Nivel 1) no puede identificar el vector de ataque en 30 minutos, escala a los Responsables Técnicos IT/OT (Nivel 2/3) o solicita la intervención de peritos forenses externos.
- **Escalamiento Ejecutivo:** Si el incidente compromete datos ciudadanos (cumpliendo criterios de Nivel Alto o Severo) o detiene la operación hídrica, los Responsables Técnicos deben escalar a la Dirección General (Mtra. Valeria Serrano Cruz) y a la Dirección Jurídica para detonar la respuesta corporativa y activar el Plan de Comunicación de Crisis.

5. Contención

El objetivo de esta fase es limitar la expansión del incidente y evitar daños mayores a la infraestructura de INTERAFAS, balanceando la necesidad de detener al atacante con la exigencia de mantener el suministro hídrico activo. Las acciones de contención se dividen en dos fases temporales para asegurar el control táctico y la resiliencia.

5.1 Estrategias de Contención Inmediata

Estas acciones se ejecutan en los primeros minutos u horas tras la confirmación del incidente para "detener la hemorragia" operativa y aislar la amenaza:

- **Aislamiento Lógico (IT):** Desconexión de la red de los servidores web o bases de datos comprometidas (ej. aislando el segmento de la Plataforma de Atención Ciudadana a nivel de *switch* o VLAN) sin apagar físicamente los equipos para no perder datos volátiles.
- **Bloqueo Perimetral:** Implementación inmediata de reglas de denegación en el Firewall perimetral y WAF para bloquear direcciones IP maliciosas identificadas, dominios de Comando y Control (C2), o patrones de tráfico anómalos (*IP Spoofing*).
- **Contención Física (OT):** Desconexión física del cableado de red que enlaza el Centro de Operación Hidráulica con la red corporativa. Transición inmediata de los controladores SCADA a operación manual, asegurando que actuadores críticos como la válvula V-SL-201 solo respondan a comandos físicos en planta.
- **Suspensión de Credenciales:** Bloqueo temporal de cuentas de usuario, administradores o tokens FIDO2 que muestren actividad comprometida o que pertenezcan a personal que reportó el incidente.

5.2 Estrategias de Contención Prolongada

Medidas implementadas para mantener la operatividad de INTERAFAS durante días o semanas mientras se investiga la raíz del problema y se diseña la solución definitiva:

- **Infraestructura Alterna (Failover):** Redireccionamiento del tráfico web ciudadano hacia servidores de respaldo limpios o sitios estáticos de "Mantenimiento" alojados en una infraestructura en la nube separada de la red principal comprometida.
- **Segmentación Reforzada:** Implementación de listas de control de acceso (ACLs) temporales y ultra-restrictivas (*Zero Trust*) entre subredes para evitar el movimiento lateral del atacante si aún permanece oculto en la red corporativa.
- **Monitoreo Intensificado:** Despliegue de agentes de detección y respuesta en *endpoints* (EDR) en todos los equipos administrativos para cazar actividad maliciosa remanente, y establecimiento de guardias presenciales 24/7 en las estaciones de bombeo de agua.

5.3 Continuidad Operativa y Gestión del Riesgo

Antes de ejecutar cualquier medida de contención, el Responsable Técnico y la Dirección General deben evaluar el riesgo de la acción frente al impacto del ataque:

- **Criterio de Riesgo Hídrico:** Nunca se apagará un servidor SCADA o un PLC si esto provoca el paro automático de las bombas de agua, a menos que exista un riesgo inminente de daño físico catastrófico (ej. sobrepresión de tuberías). La continuidad del suministro mediante control mecánico es prioritaria.
- **Criterio de Riesgo de Datos:** Si se detecta una inyección SQL activa exfiltrando expedientes ciudadanos, se autoriza la "caída" intencional (desconexión) del portal web, asumiendo el impacto reputacional a cambio de frenar el robo de información sensible.

5.4 Preservación de Evidencia

Toda estrategia de contención debe diseñarse para no destruir pruebas vitales para el análisis forense posterior y las notificaciones legales al INAI o la Fiscalía:

- **Prohibición de Apagado (Pull the Plug):** Se instruye al personal a aislar las máquinas desconectando el cable de red, prohibiendo estrictamente apagar los equipos (*shut down* o corte de energía), para salvaguardar la memoria RAM, los procesos en ejecución y las conexiones de red activas de los atacantes.
- **Clonación Previa:** Antes de aplicar parches de seguridad de emergencia o restaurar un servicio en la fase prolongada, se debe asegurar que el equipo de respuesta a incidentes haya tomado imágenes forenses de los discos y respaldado las bitácoras (*logs*).

6. Erradicación y Remediación (PR02-36)

El objetivo de la fase de erradicación es eliminar la causa raíz del incidente, expulsar definitivamente a los actores de amenazas de la red de INTERAFAS y parchear las vulnerabilidades que permitieron la intrusión, asegurando que los sistemas estén limpios antes de autorizar su retorno a la operación productiva.

6.1 Eliminación de Causas y Corrección de Vulnerabilidades

Derivado del triaje y análisis forense, el equipo técnico (IT/OT) debe ejecutar las siguientes acciones correctivas según el vector de ataque identificado:

- **Vulnerabilidades Web (IDOR / SQLi):**
    - Reescribir el código fuente de los endpoints afectados en la Plataforma de Atención Ciudadana para implementar sentencias SQL parametrizadas (eliminando la Inyección SQL ciega).

    - Implementar un control de acceso basado en roles (RBAC) estricto en el backend para validar la propiedad de los objetos antes de mostrarlos, eliminando la vulnerabilidad IDOR.

- **Ataques Perimetrales (IP Spoofing / Evasión):**
    - Configurar el WAF para descartar la cabecera X-Forwarded-For si no proviene de un proxy inverso autorizado de la propia institución.
    - Ajustar el filtrado de red (Firewall) para denegar tráfico entrante desde la WAN que declare pertenecer a rangos de IP internos (prevención de *spoofing*).
- **Sistemas de Control Industrial (SCADA):**
    - Si un nodo RTU o PLC (RTU-GW-07) fue comprometido mediante una actualización falsa, el Responsable Técnico OT debe hacer un flasheo a nivel de hardware (*Hardware Reset*), instalando la versión de *firmware* original (Golden Image) directamente desde un dispositivo físico seguro, validando su firma criptográfica (hash SHA-256).

6.2 Eliminación de Persistencia

Los atacantes suelen dejar "puertas traseras" (backdoors) para garantizar su regreso. La erradicación exige limpiar cualquier rastro de persistencia:

- **Limpieza de Cuentas:** Auditoría inmediata del *Active Directory*. Se deben identificar y eliminar cuentas de usuario con privilegios escalados que hayan sido creadas en las últimas 72 horas.
- **Reseteo Criptográfico:** Cambio masivo y obligatorio de contraseñas de todos los administradores IT/OT. Revocación de llaves SSH, tokens API expuestos y certificados digitales comprometidos en el portal de pagos.
- **Caza de Malware:** Escaneo profundo (Heurística y Firmas) de todos los servidores utilizando los indicadores de compromiso (IoCs) detectados durante la fase de análisis para eliminar scripts maliciosos, *webshells* ocultas o archivos .exe anómalos.

6.3 Validación de Controles antes de Recuperar

Antes de iniciar la fase de Recuperación, la Dirección General debe recibir una certificación técnica de que el entorno es seguro:

1. **Auditoría de Vulnerabilidades (VAPT):** El equipo consultor o de auditoría interna debe ejecutar un escaneo de caja blanca sobre la plataforma web y los controladores SCADA para confirmar que los parches aplicados (SQLi, IDOR) son efectivos y no pueden ser *bypasseados*.
2. **Verificación de Aislamiento:** Confirmación de que las reglas *Zero Trust* están activas y que no existe comunicación entre la VLAN administrativa e industrial, excepto por los puertos estrictamente necesarios.

3. **Firma de Certificación:** El Ing. Bruno Ferrer (IT) y el Ing. Tomás Rivas (OT) firman la bitácora de erradicación, certificando a la Dirección General que la amenaza ha sido eliminada y solicitando el pase a la fase de restauración del servicio.

7. Recuperación

La fase de recuperación consiste en restaurar los sistemas y la infraestructura tecnológica a su estado operativo normal (pre-incidente), asegurando que la red esté libre de amenazas, que los datos estén íntegros y que no existan vulnerabilidades residuales que permitan un ataque secundario.

7.1 Procedimientos de Restauración Segura

Ningún sistema IT o nodo OT puede ser reconectado a la red de producción sin cumplir el siguiente protocolo:

1. **Reconstrucción desde Cero (Wipe and Rebuild):** Para servidores gravemente comprometidos (ej. donde se ejecutó *malware* o se logró escalación de privilegios), no se intentará "limpiar" el sistema operativo. Se formatearán los discos físicos y se reinstalarán los sistemas operativos (ej. Linux/Windows Server) desde imágenes seguras (Golden Images) alojadas en repositorios inmutables.
2. **Restauración de Datos (Backups):** Las bases de datos ciudadanas se restaurarán exclusivamente a partir de las copias de seguridad (Regla 3-2-1) cuya fecha de creación sea **anterior** al primer indicador de compromiso (IoC) detectado en la red.
3. **Despliegue de Controladores (OT):** Para la red industrial, los controladores (V-SL-201, RTU-GW-07) serán reprogramados con las lógicas de control originales desde estaciones de ingeniería físicamente aisladas de internet.

7.2 Pruebas y Validación Funcional

Antes de permitir el acceso a los ciudadanos o ceder el control automático a las bombas, los sistemas deben ser validados en un entorno de pruebas (*Sandboxing / Staging*):

- **Pruebas de Estrés y QA:** El área de Tecnologías de la Información verificará la integridad de la base de datos restaurada y la funcionalidad del código web parcheado.
- **Auditoría de Inyección (SQLi) y Acceso (IDOR):** Ejecución de *scripts* de prueba automatizados para confirmar que los vectores del ataque original ya no son explotables.
- **Calibración SCADA:** El área de Operación Hidráulica ejecutará rutinas de prueba locales (sin flujo de agua) en los actuadores para confirmar que los controladores responden adecuadamente a los comandos del nuevo firmware.

7.3 Monitoreo Reforzado (Hypercare)

Durante los primeros 14 días posteriores a la restauración, los sistemas recuperados operarán bajo un régimen de vigilancia extrema:

- El SIEM se configurará para emitir alertas de "Prioridad 1" ante cualquier intento de inicio de sesión fallido o tráfico inusual proveniente de las redes recién restauradas.
- Se requerirá autorización dual (MFA + Aprobación por Ticket) para cualquier cambio de configuración en el firewall perimetral o en los ruteadores industriales.

7.4 Criterios para Volver a Operación (Go-Live)

La autorización para transicionar de la fase de recuperación a la operación productiva general (reapertura del portal web y habilitación del bombeo automático) requiere la aprobación por escrito de tres actores:

1. **Ing. Bruno Ferrer Lozano (IT):** Certifica la integridad de los datos y el cierre de vulnerabilidades.
2. **Ing. Tomás Rivas Calderón (OT):** Certifica la respuesta correcta de los actuadores en pruebas de campo.
3. **Mtra. Valeria Serrano Cruz (DG):** Otorga el "Visto Bueno" final asumiendo la responsabilidad institucional del reinicio.

7.5 Mecanismos de Rollback (Marcha Atrás)

Si durante las primeras 24 horas de operación post-recuperación se detecta un comportamiento anómalo (ej. lentitud extrema, errores en la base de datos o intentos de reinfección), se activará el plan de *rollback*:

- **Condición de Activación:** Detección de cualquier IoC remanente o inestabilidad que afecte el suministro hídrico.
- **Acción:** Desconexión inmediata de los servicios afectados (se "baja el *switch*") y retorno de la operación a la Fase de Contención Prolongada (infraestructura alterna y bombeo manual) hasta que el equipo de respuesta reevalúe el entorno.

8. Coordinación y Comunicación (PR02-38)

El escalamiento ejecutivo dentro del Plan de Respuesta ante Incidentes se detona en el momento exacto en que el equipo técnico confirma que una amenaza supera las capacidades de contención del primer nivel operativo o cuando se identifica un riesgo directo para la infraestructura crítica y los datos ciudadanos. En este punto, el Responsable Técnico (IT u OT) transfiere la situación a la Dirección General, quien asume el liderazgo absoluto y activa simultáneamente el Plan de Comunicación de Crisis. Esta coordinación garantiza que el equipo de ciberseguridad no se distraiga atendiendo a la prensa o al público, ya que la

Dirección de Atención Ciudadana traduce los hallazgos técnicos forenses en mensajes claros y oportunos para la población, evitando contradicciones y pánico.

La colaboración con entidades externas y autoridades es un pilar ineludible en esta fase. La Dirección Jurídica asume la responsabilidad de notificar de manera formal al Instituto Nacional de Transparencia (INAI) dentro de las primeras 72 horas si se confirma la exfiltración de información confidencial. Paralelamente, la Dirección General mantiene una línea de comunicación directa y constante con la CONAGUA y el gobierno municipal para coordinar la logística de abastecimiento alterno, como el despliegue de pipas, en caso de que el ciberataque obligue a detener las estaciones de bombeo. Adicionalmente, el área de Tecnologías de la Información se encarga de alertar a los proveedores tecnológicos de terceros, como el servicio de alojamiento web y la pasarela de pagos, para que apliquen bloqueos desde sus propias fronteras de red y proporcionen las bitácoras necesarias para la investigación.

9. Playbooks Operativos (PR02-39)

Para garantizar una respuesta técnica estandarizada y evitar la improvisación durante una crisis, el equipo CSIRT-INTERAFAS debe ejecutar los siguientes *playbooks* (guías de acción) ante la detección de incidentes específicos:

Playbook 1: Inyección SQL en Plataforma de Atención Ciudadana

- **Disparador:** Alertas del WAF por sintaxis anómala (ej. ' OR 1=1--) en formularios web o picos inusuales de consultas a la base de datos de expedientes.
- **Responsables:** Analista SOC (Nivel 1) para detección; Desarrollador Web y Administrador de Base de Datos para contención y remediación.
- **Acciones:**
    - Verificar si la inyección logró extraer datos (SQLi Ciega o Basada en Errores).
    - Aislar la base de datos de producción conectándola a una red de solo lectura.
- **Evidencia:** Volcado (*dump*) de los registros del servidor web (access.log), consultas del motor SQL y captura de tráfico de red perimetral.
- **Contención:** Aplicar reglas de bloqueo en el WAF para la IP atacante y deshabilitar temporalmente el módulo de consultas ciudadanas del portal.
- **Recuperación:** Reescribir el código fuente del portal utilizando sentencias SQL parametrizadas (Prepared Statements).
- **Criterio de Cierre:** Escaneo de vulnerabilidades (SAST/DAST) en un entorno de pruebas que certifique que el formulario ya no es vulnerable a inyecciones.

Playbook 2: Explotación de IDOR (Acceso No Autorizado a Expedientes)

- **Disparador:** Detección de descargas secuenciales de documentos PDF o recibos de agua modificando los parámetros de la URL (ej. de folio=100 a folio=101) por un mismo usuario autenticado.
- **Responsables:** Analista de Seguridad IT y Dirección Jurídica (para evaluar el impacto legal por exposición de datos).
- **Acciones:**
    - Auditar los registros de acceso para cuantificar exactamente cuántos y cuáles expedientes fueron descargados de forma ilícita.
    - Identificar la cuenta de usuario que está realizando la enumeración.
- **Evidencia:** Registros de sesión del usuario atacante, bitácoras del balanceador de carga y copias de los folios exfiltrados.
- **Contención:** Forzar el cierre de sesión masivo en el portal web y suspender la cuenta del atacante.
- **Recuperación:** Implementar un control de acceso basado en roles (RBAC) en el *backend*, validando que el ID del objeto solicitado corresponda al ID del usuario en sesión.
- **Criterio de Cierre:** Pruebas funcionales de control de acceso exitosas y notificación al INAI sobre los expedientes comprometidos.

Playbook 3: Manipulación Remota de Nodos SCADA (V-SL-201)

- **Disparador:** Pérdida repentina de comunicación con las Unidades Terminales Remotas (RTU) o lecturas de telemetría erráticas (ej. falsa sobrepresión) en el Centro de Control Hidráulico.
- **Responsables:** Ing. Tomás Rivas (Responsable Técnico OT) y Jefes de Cuadrilla en Planta.
- **Acciones:**
    - Despliegue inmediato de operadores a las válvulas físicas para inspección ocular.
    - Aislar la red de control industrial de cualquier conexión corporativa o de internet.
- **Evidencia:** Volcado de memoria de los Controladores Lógicos Programables (PLC) afectados y registros del tráfico de la red industrial (buscapersonas/Modbus).

- **Contención:** Transición inmediata del control automatizado a control manual (mecánico) de las bombas y válvulas.
- **Recuperación:** Flasheo a nivel de hardware (*Hardware Reset*) de los PLC y reinstalación del *firmware* original desde un repositorio seguro (*Golden Image*).
- **Criterio de Cierre:** El sistema SCADA opera en modo automático durante 24 horas sin registrar anomalías ni comandos fantasma.

Playbook 4: Intrusión Perimetral por IP Spoofing

- **Disparador:** Alertas del IDS perimetral indicando tráfico entrante desde internet (WAN) que falsifica su origen utilizando direcciones IP de la red interna de INTERAFAS (ej. rango 192.168.x.x o 10.x.x.x).
- **Responsables:** Administrador de Redes y Firewall.
- **Acciones:**
    - Rastrear la verdadera IP de origen analizando las tablas de enrutamiento del proveedor de servicios de internet (ISP).
- **Evidencia:** Captura de paquetes crudos (*pcap*) del tráfico anómalo en la interfaz externa del firewall.
- **Contención:** Configurar reglas de denegación estrictas (Anti-Spoofing) en el firewall perimetral para descartar automáticamente paquetes entrantes con IP internas.
- **Recuperación:** Revisar la configuración del *Gateway* para asegurar que ignora cabeceras HTTP manipuladas como X-Forwarded-For.
- **Criterio de Cierre:** Simulaciones de ataque (Red Teaming) demuestran que el firewall bloquea efectivamente los intentos de falsificación de origen.

Playbook 5: Compromiso de Credenciales de la Mesa de Soporte (MFA Bypass)

- **Disparador:** Inicios de sesión exitosos en servidores críticos o paneles de administración fuera del horario laboral, o múltiples inicios de sesión simultáneos desde diferentes ubicaciones geográficas.
- **Responsables:** Administrador de Identidad (*Active Directory*) y Responsable de Cumplimiento.
- **Acciones:**
    - Identificar qué sistemas o bases de datos fueron accedidos por la cuenta comprometida.
    - Validar si se crearon cuentas secundarias (persistencia) por parte del atacante.

- **Evidencia:** Registros de autenticación del Controlador de Dominio (Event Logs de Windows) y bitácoras de acceso a la VPN institucional.
- **Contención:** Revocar inmediatamente la credencial comprometida, deshabilitar la cuenta de VPN del usuario y forzar el cierre de sus sesiones activas.
- **Recuperación:** Restaurar las configuraciones alteradas por el atacante y provisionar nuevas credenciales al usuario original exigiendo obligatoriamente un token de hardware (FIDO2) intransferible.
- **Criterio de Cierre:** Auditoría de permisos confirma que la cuenta original no dejó "puertas traseras" y que la política de MFA por hardware (PF-07) está activa y funcional.

10. Post-Incidente y Mejora

La contención técnica de un ciberataque y la restauración del suministro de agua en INTERAFAS marcan únicamente el fin de la etapa táctica de la emergencia. La fase de Post-Incidente representa el pilar estratégico de la resiliencia institucional, cuyo propósito es transformar una crisis operativa en un ciclo estructurado de mejora continua para el Sistema de Gestión de Seguridad de la Información (SGSI). Esta etapa garantiza que las vulnerabilidades sistémicas sean erradicadas de raíz, evitando la recurrencia de vectores de ataque similares en el futuro.

10.1 Declaratoria y Cierre Formal del Incidente

El cierre de la contingencia no es un evento automático; requiere un protocolo formal de entrega y aceptación para garantizar que no existan riesgos residuales activos.

- **Acta de Cierre de Contingencia:** Documento oficial firmado por la Dirección General (Mtra. Valeria Serrano Cruz) que decreta el fin del estado de emergencia, emitido única y exclusivamente tras recibir la certificación técnica (IT/OT) de que la red se encuentra limpia y funcional.
- **Periodo de *Hypercare* (Monitoreo Reforzado):** Previo a la desmovilización total, se establece una ventana de 72 horas donde el Centro de Operaciones de Seguridad (SOC) mantiene una vigilancia extrema sobre los nodos SCADA y la plataforma web para descartar intentos de reinfección.
- **Desmovilización:** Una vez superado el *Hypercare*, se disuelve formalmente el "Comando de Incidentes" (*War Room*), cesan las comunicaciones de crisis a la ciudadanía y las cuadrillas operativas regresan a sus esquemas de turnos habituales.

10.2 Elaboración del Informe Final

En un plazo máximo de cinco días hábiles tras la firma del Acta de Cierre, el equipo CSIRT-INTERAFAS presentará un reporte exhaustivo ante la Dirección General. Este informe se redacta bajo una cultura *Blameless* (libre de culpas), enfocándose en las fallas de los procesos y no en señalar a individuos. El documento debe integrar:

- **Análisis Causa Raíz (RCA):** Utilización de metodologías como los "5 Porqués" para determinar exactamente cómo los atacantes lograron evadir el perímetro, explotar las vulnerabilidades web (IDOR/SQLi) y pivotar hacia la red industrial.
- **Línea de Tiempo Forense:** Reconstrucción cronológica exacta desde la fase de reconocimiento del atacante, el primer indicador de compromiso (IoC), hasta la exfiltración de los expedientes y la manipulación de la válvula V-SL-201.
- **Impacto Operativo y Financiero Cuantificado:** Evaluación del costo real del incidente, incluyendo horas-hombre invertidas en la recuperación, volumen de agua no distribuida, impacto reputacional y la cantidad exacta de los expedientes ciudadanos comprometidos.

10.3 Plan de Acción Correctiva y Preventiva (CAPA) y Lecciones Aprendidas

El corazón de la mejora continua radica en traducir los hallazgos del informe Post-Mortem en soluciones tangibles y auditables. Las acciones correctivas se categorizarán en tres frentes estructurales:

- **Acciones Tecnológicas:** Corrección definitiva de fallas de *software* y *hardware*. Por ejemplo, tras el hallazgo de inyecciones SQL, se exigirá la reescritura del código fuente y la contratación de pruebas de penetración (*Pentesting*) semestrales. Ante el robo de datos, se forzará la implementación de autenticación multifactor (FIDO2) en todas las cuentas con privilegios.
- **Acciones Operativas (SCADA):** Si la desconexión de la red industrial presentó retrasos, se rediseñará la segmentación lógica (VLANs restrictivas) entre el entorno IT y OT. Asimismo, se optimizarán los protocolos mecánicos de las bombas de agua para acelerar la transición al control manual.
- **Acciones Administrativas y Documentales:** Actualización inmediata de la Matriz de Riesgos del SGSI (elevando la probabilidad de ocurrencia de intrusiones) y modificación de las políticas de acceso a la información confidencial.

10.4 Métricas de Evaluación de Desempeño (KPIs de Respuesta)

Para asegurar que la capacidad defensiva de la institución evoluciona favorablemente, el Comité de Seguridad medirá el desempeño del equipo de respuesta utilizando los siguientes indicadores clave:

- **MTTD (Tiempo Promedio de Detección):** Medición en minutos desde que la intrusión inició hasta que las herramientas de seguridad (SIEM/WAF) o el personal generaron la alerta oficial.
- **MTTC (Tiempo Promedio de Contención):** Evaluación de la velocidad del equipo para frenar la propagación del ataque y detener la fuga de datos una vez detectada la amenaza.
- **MTTR (Tiempo Promedio de Recuperación):** Cálculo del total de horas necesarias para restaurar los servicios críticos de manera segura (bombeo SCADA y portal ciudadano).
- **SLA de Cumplimiento Legal:** Verificación binaria (Cumple / No Cumple) sobre si la Dirección Jurídica logró notificar la brecha de datos personales al INAI dentro del margen de 72 horas estipulado por la ley.

10.5 Gobernanza, Responsables y Seguimiento hasta la Resolución

Ningún hallazgo debe quedar archivado sin solución. La gobernanza de la fase de mejora se ejecutará mediante un seguimiento directivo riguroso:

- **Matriz de Asignación:** La Dirección General nombrará a un directivo titular para cada una de las acciones correctivas estipuladas, definiendo fechas de entrega inamovibles (ej. "La segmentación de la red OT debe concluirse el 15 de noviembre bajo la responsabilidad del Ing. Tomás Rivas").
- **Comité de Seguimiento:** Se instaurará una mesa de revisión ejecutiva de frecuencia mensual. En este foro, los responsables deberán presentar el estatus de avance de sus asignaciones.
- **Cierre de Hallazgos y Auditoría:** Una acción correctiva no se declara como "Resuelta" simplemente por un reporte verbal. Requiere evidencia técnica comprobable (como reportes de escaneo de vulnerabilidades limpios, diagramas de red actualizados o bitácoras del *firewall* certificadas) que demuestre que el hueco de seguridad ha sido sellado de forma permanente en la infraestructura de INTERAFAS.

Conclusion

La estructuración de este Plan de Respuesta ante Incidentes (CSIRT-INTERAFAS) representa un paso decisivo en la consolidación de la resiliencia operativa del organismo. Al alinear los protocolos de contención técnica, análisis forense y recuperación segura bajo los lineamientos del estándar ISO/IEC 27001, INTERAFAS garantiza la protección simultánea de dos frentes críticos: la privacidad de los datos ciudadanos en el entorno IT y la continuidad ininterrumpida del suministro hídrico en la infraestructura industrial OT (SCADA).

Más allá de mitigar el impacto inmediato de un ciberataque a través de *playbooks* tácticos y escalamientos ejecutivos, este documento institucionaliza una cultura de seguridad proactiva. Al hacer obligatorio el análisis forense post-mortem y la implementación de acciones correctivas auditables, se asegura que cada eventualidad técnica se transforme en un blindaje a largo plazo. De esta manera, el organismo no solo cumple con las exigencias normativas y legales de protección de datos, sino que blinda operativamente el servicio más esencial para el bienestar y desarrollo de la zona metropolitana de San Luis Potosí frente a un panorama de amenazas digitales cada vez más sofisticado.